Name: Bamidele Covenant Ayomide

Matric Number: RUN/CYB/23/15390

Assignment: CVE-2023-34362

Introduction

CVE-2023-34362 refers to a critical SQL injection vulnerability discovered in Progress Software's MOVEit Transfer application. The vulnerability was exploited in real world attacks in May and June 2023.

Vulnerability details from NVD

Attribute of the CVE	Detail of the CVE
CVE ID	CVE-2023-34362
Vulnerability type	SQL injection
Affected product	Progress MOVEit Transfer
Weakness classification	CWE-89
Date published	2nd June 2023
CVSS version	CVSS 3.1
Base score	9.8 out of 10
Severity	Crtitical
Attack sector	Network
Authentication/ Privileges required	None
User interaction required	None
Known exploitation	Yes

Description of the vulnerability

SQL injection occurs when an application improperly handles user-supplied input used in SQL database queries. An attacker can manipulate the query to make the database perform unintended operations.

In CVE-2023-34362, the vulnerability existed in the web application of MOVEit Transfer, a managed file-transfer solution used by organizations to exchange files securely.

An unauthenticated remote attacker could exploit the flaw to access the application's database. Depending on the database engine, the attacker could obtain information about the database's structure and contents and execute SQL statements that modify or delete database elements.

Possible consequences

Confidentiality: Exposure or theft of sensitive information.

Integrity: Unauthorized modification of database records.

Availability: Deletion or alteration of data could disrupt services.

Business impact: Data breaches, financial losses, reputational damage and possible regulatory consequences.

The vulnerability is particularly serious because an attacker does not need an existing account or user interaction to attempt exploitation.

Severity score and its meaning

The NVD assigns CVE-2023-34362 a CVSS v3.1 score of 9.8/10 — Critical.

CVSS stands for Common Vulnerability Scoring System. It measures the technical severity of a vulnerability on a scale from 0.0 to 10.0.

CVSS metric	Value	Explanation
Attack Vector (AV)	Network	The vulnerability can be exploited remotely over a network.
Attack Complexity (AC)	Low	Exploitation does not require unusually difficult conditions.
Privileges Required (PR)	None	The attacker does not need an account or existing privileges.
User Interaction (UI)	None	A victim does not need to click a link or perform an action.
Scope (S)	Unchanged	The vulnerable component's security authority is not classified as changing under this metric.
Confidentiality (C)	High	Sensitive information could be disclosed.
Integrity (I)	High	Data could be modified or destroyed.
Availability (A)	High	Data or service availability could be affected.

The CVSS vector is:

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

These characteristics explain why the vulnerability received a critical score: it is remotely exploitable, requires no privileges and can seriously affect confidentiality, integrity and availability.

Patch and remediation

Progress Software released a security update for CVE-2023-34362 on 31 May 2023. The vendor's initial fixed versions for MOVEit Transfer were as follows.

Affected version branch	Initial fixed version
2021.0.x	2021.0.6
2021.1.x	2021.1.4
2022.0.x	2022.0.4
2022.1.x	2022.1.5
2023.0.x	2023.0.1

Important: These are the initial versions that addressed CVE-2023-34362, not necessarily the safest versions to install today. Subsequent MOVEit vulnerabilities required further updates. Administrators should follow the vendor's current guidance and install an appropriately supported, fully updated version.

Recommended remediation steps

- Identify all servers running MOVEit Transfer, including older or unsupported installations.
- Restrict HTTP and HTTPS access to the MOVEit Transfer environment while preparing the fix, as directed by the vendor.
- Apply the appropriate vendor security update or upgrade to a supported version.

- Follow the vendor's instructions for verifying the update and restoring access.

- Examine system logs, web server activity and indicators of compromise to determine whether the vulnerability was exploited before patching.

- If compromise is suspected, isolate affected systems, preserve evidence, investigate possible data theft and rotate potentially exposed credentials or secrets as appropriate.

- Continue monitoring the system for suspicious activity.

Analysis of CVE-2023-34362 using the Cyber Kill Chain

The Cyber Kill Chain is a security model developed by Lockheed Martin to describe the stages attackers may follow during a cyberattack. It helps cybersecurity professionals identify where an attack can be detected, prevented or disrupted.

The MOVEit exploitation campaign attributed to the CL0P threat group provides a real-world example of how these stages can be applied. The FBI and CISA reported that attackers exploited the vulnerability to install a malicious web shell known as LEMURLOOT and steal data.

Stage 1: Reconnaissance

Attackers identify organizations using MOVEit Transfer, particularly internet-facing installations that may be vulnerable.

Defence: Maintain an asset inventory, identify exposed services and perform regular vulnerability assessments.

Stage 2: Weaponization

The attacker prepares or uses an SQL injection technique to exploit the vulnerable application. In this campaign, the exploit could be used to facilitate the installation of a web shell.

Defence: Use secure coding practices, parameterized SQL queries, code reviews and application security testing.

Stage 3: Delivery

Malicious HTTP or HTTPS requests are sent to the vulnerable MOVEit web application. Unlike phishing attacks, this attack path does not require a victim to open an attachment or click a link.

Defence: Restrict unnecessary internet exposure, monitor web requests and apply appropriate network security controls.

Stage 4: Exploitation

The attacker exploits the SQL injection flaw to interact with the underlying database without legitimate authentication.

Defence: Patch the vulnerability, inspect suspicious requests and investigate possible database access.

Stage 5: Installation

In documented attacks, the attackers installed LEMURLOOT, a malicious web shell that could masquerade as a legitimate MOVEit application file.

Defence: Monitor for unexpected web files, verify file integrity and use endpoint detection tools to identify suspicious changes.

Stage 6: Command and Control

The web shell accepted specially formatted HTTP requests from its operators. This provided a way to interact with the compromised application.

Defence: Examine unusual HTTP headers, web server logs and outbound connections. The exact command-and-control pattern should be established from incident evidence.

Stage 7: Actions on Objectives

The attackers used the compromised application to retrieve sensitive information and exfiltrate files. The campaign resulted in data theft and subsequent extortion threats against affected organizations.

Defence: Monitor unusual file access and data transfers, isolate compromised systems, preserve evidence and follow the incident response process.

The stages above are an analytical mapping of the documented campaign to the Cyber Kill Chain. Not every attack necessarily follows all seven stages in order. Source: FBI/CISA and Mandiant reporting.

Cybersecurity experts response

The response to CVE-2023-34362 involved the software vendor, cybersecurity researchers and government cybersecurity agencies.

Progress Software: Progress Software disclosed the vulnerability and released an initial security update on 31 May 2023. It provided remediation guidance to customers and continued investigating the incident and related vulnerabilities.

CISA and the FBI: The Cybersecurity and Infrastructure Security Agency (CISA) and the Federal Bureau of Investigation (FBI) published a joint advisory on the CL0P campaign. Their response included:

- Sharing known indicators of compromise and attacker techniques.
- Advising organizations to identify and patch vulnerable MOVEit installations.
- Recommending security monitoring, asset inventories and least-privilege access.
- Encouraging affected organizations to investigate possible compromise and protect sensitive information.

Cybersecurity researchers and incident responders: Researchers investigated the SQL injection vulnerability, analyzed the LEMURLOOT web shell and documented evidence of data theft. These findings helped defenders identify suspicious files and requests and understand how the attacks were carried out.

Recommended incident response procedure

An organization that suspects exploitation should follow these steps:

- Preparation: Maintain backups, incident response procedures and an accurate inventory of MOVEit installations.
- Identification: Review application logs, web server logs, file changes and indicators of compromise.
- Containment: Restrict network access or isolate the affected server to prevent further malicious activity.

- Eradication: Remove the malicious web shell and other attacker artifacts after preserving relevant evidence, and address the original vulnerability.

- Recovery: Apply the appropriate security updates, verify system integrity and restore operations safely.

- Post-incident review: Determine what information was accessed or stolen, notify appropriate stakeholders where required and improve security controls.

- Important: Installing a patch does not prove that a previously vulnerable server was never compromised. Organizations must investigate possible prior exploitation as well as update the software.

Conclusion

CVE-2023-34362 demonstrates the serious risks associated with unpatched internet-facing applications. The SQL injection vulnerability in Progress MOVEit Transfer received a CVSS v3.1 score of 9.8, classified as Critical, because it could be exploited remotely without authentication and could affect the confidentiality, integrity and availability of data.

The documented CL0P campaign shows how exploitation can lead to the installation of a web shell and the theft of sensitive information. The incident highlights the importance of timely patching, secure application development, continuous monitoring, incident response planning and collaboration between software vendors, researchers and cybersecurity agencies.